

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Prompt Firebreak Audit Template

Audit your prompt-layer defenses: where untrusted input can reach your agents. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

Prompt Firebreak Audit Template

Version 1.0 For AI Agents in Production Environments Governance, Risk, and Compliance Framework

1. Executive Summary

This **Prompt Firebreak Audit Template** is designed for organizations deploying AI agents in production to systematically assess and mitigate risks associated with unintended behavior, data leakage, cost escalation, and compliance violations. The template aligns with **NIST AI Risk Management Framework (RMF)**, **ISO/IEC 42001 (AI Management Systems)**, and **GDPR/AICPA SOC 2 controls** for AI governance.

Purpose: - Ensure AI agents adhere to predefined behavioral boundaries. - Validate permissioning, audit trails, and incident response mechanisms. - Enforce cost controls and data sovereignty. - Prevent catastrophic failures (e.g., hallucinations, adversarial prompts, or data exfiltration).

Scope: Applies to all AI agents (LLMs, RAG systems, autonomous agents) integrated into production workflows, including: - Customer-facing chatbots - Internal decision-support agents - Automated workflow orchestrators - Data processing pipelines

2. Audit Structure & Fields

Each section contains **mandatory fields** with **real-world governance requirements**. Auditors must verify compliance via system logs, configuration files, and third-party validation tools.

Section 1: Agent Identity & Classification

Field	Requirement	Acceptance Criteria
Agent Name	Official internal/external name.	Must match deployment documentation.
Agent Type	LLM, RAG, Hybrid, Autonomous, or Other.	Classified per [Company AI Taxonomy Policy].
Owner/Steward	Primary contact for governance.	Must be a named individual with escalation rights.
Deployment Environment	Cloud (AWS/GCP/Azure), On-Prem, or Edge.	Must align with [Company Cloud Classification Policy].
SLA/Service Level	Expected uptime, latency, and throughput.	Documented in [Service Level Agreement (SLA) for AI Agents].
Compliance Designation	GDPR, HIPAA, CCPA, or Other.	Must reflect data sensitivity per [Data Classification Policy].
Risk Rating	Low/Medium/High/Critical (based on impact analysis).	Assigned via [Company AI Risk Assessment Tool].

Verification Method: - Cross-check with **IAM logs** and **deployment manifests**. - Confirm **owner contact** via HR/ITAD records.

Section 2: Behavioral Firebreaks (Prompt & Output Controls)

Subsection	Field	Requirement	Acceptance Criteria
Input Validation	Prompt Sanitization	Must strip/mask PII, toxic content, and adversarial patterns.	Use OpenAI Moderation API, Hugging Face Filter, or custom regex rules.
	Rate Limiting	Max tokens/second, max concurrent requests.	Enforced via API Gateway (Kong/Nginx) or Cloudflare WAF.
	Blocklist Terms	Hard-coded or dynamic blocklists (e.g., "delete my account," "hack me").	Maintained in GitHub/GitLab repo or HashiCorp Vault.
Output Safeguards	Truthfulness Guarantee	Must cite sources for factual claims (RAG agents only).	Enforced via source verification middleware (e.g., LangChain Retriever checks).
	Hallucination Mitigation	Must flag uncertain responses with "Unsure" or "Check Source."	Configured in LLM response templates (e.g., {"uncertainty": true}).
	Toxicity Threshold	Auto-reject prompts scoring >0.8 (Perspective API).	Logged in Sentry/ELK Stack for review.
Adversarial Defense	Jailbreak Detection	Must detect and block "role-playing" or "ignoring instructions" prompts.	Use PromptLeaks or custom LLM fine-tuning on adversarial datasets.
	Cost Escalation Alerts	Trigger at \$X/hour (e.g., \$100).	Monitored via Cloud Cost Explorer + Slack/PagerDuty alerts.

Verification Method: - Test with **adversarial prompt sets** (e.g., [Prompt Injection Red Team](#)). - Review **API call logs** for blocked/flagged interactions.

Section 3: Permissioning & Access Controls

Subsection	Field	Requirement	Acceptance Criteria
IAM Integration	Role-Based Access	Agents must operate under least-privilege roles (e.g., ai-agent-read-only).	Enforced via AWS IAM, GCP IAM, or Azure RBAC.
	API Key Rotation	Keys rotated every 30 days.	Audited via AWS Secrets Manager or HashiCorp Vault.

Subsection	Field	Requirement	Acceptance Criteria
Data Sovereignty	Geographic Restrictions	Must comply with [Company Data Residency Policy].	Enforced via Cloud Provider Region Locks (e.g., AWS aws:SourceVpc).
	PII Handling	Must redact PII in logs/outputs (per GDPR Article 5).	Validated via Datadog/FireHydrant PII scanning.
Audit Trails	Immutable Logs	All agent interactions logged with timestamp, user ID, prompt, response.	Stored in AWS CloudTrail, GCP Audit Logs, or Splunk.
	Retention Policy	Logs retained for 12 months (or per [Company Data Retention Policy]).	Enforced via AWS S3 Lifecycle Policies.

Verification Method: - Run **IAM access analyzer** (AWS) or **GCP IAM Recommender**. - Query logs for **anonymized PII** using **AWS Athena** or **BigQuery**.

Section 4: Cost & Resource Governance

Field	Requirement	Acceptance Criteria
Budget Guardrails	Hard cap at \$Y/month (e.g., \$5,000).	Enforced via Cloud Cost Anomaly Detection (GCP) or AWS Budgets.
Usage Monitoring	Real-time tracking of tokens, API calls, and compute hours.	Visualized in Cloud Console Dashboards or Datadog.
Auto-Shutdown	Agents pause after X hours of inactivity (e.g., 6).	Configured via AWS Lambda or Kubernetes Horizontal Pod Autoscaler.
Cost Alert Thresholds	Alert at 80% of budget.	Triggered via Slack/Email (e.g., PagerDuty).
Vendor Lock-in Mitigation	Multi-cloud support or open-source fallback.	Documented in [Company AI Disaster Recovery Plan].

Verification Method: - Export **cost reports** from Cloud Provider and validate against **ERP budget tools**. - Test **auto-shutdown** by simulating idle periods.

Section 5: Incident Response & Post-Mortems

Field	Requirement	Acceptance Criteria
Escalation Path	Named AI Incident Response Team (AIRT) with 24/7 coverage.	Documented in [Company AI Incident Playbook].
Detection & Triage	Automated alerts for hallucinations, data leaks, or cost spikes.	Logged in Sentry or Datadoc.

Field	Requirement	Acceptance Criteria
Containment	Ability to pause/rollback agent in <15 minutes.	Enforced via Terraform/IaC rollback scripts.
Root Cause Analysis	Post-incident report with 5 Whys and mitigation plan.	Stored in Jira/Confluence with audit trail.
Lessons Learned	Updates to firebreak rules based on incidents.	Documented in GitHub Wiki or Notion Knowledge Base.

Verification Method: - Conduct **tabletop exercise** simulating a **data leak** or **cost overrun**. - Review **past incident reports** for **mitigation effectiveness**.

Section 6: Third-Party & Vendor Risk

Field	Requirement	Acceptance Criteria
LLM Provider SLAs	Must include downtime guarantees (<1% uptime).	Reviewed via OpenAI Status Page or Mistral SLA.
Data Processing Agreements (DPAs)	Signed DPA with LLM provider.	Stored in Legal Compliance Database.
Audit Rights	Ability to audit provider logs upon request.	Confirmed via vendor contract clause.
Fallback Plan	Documented Plan B (e.g., switch to Hugging Face Inference API).	Tested via disaster recovery drills.

Verification Method: - Pull **vendor contract clauses** from **Legal Team**. - Test **fallback deployment** in staging.

Section 7: Continuous Monitoring & Validation

Field	Requirement	Acceptance Criteria
Automated Compliance Checks	Daily scans for prompt leaks, cost spikes, or policy violations.	Run via GitHub Actions or Terraform Cloud.
Penetration Testing	Quarterly red team exercises (e.g., Prompt Injection Attacks).	Logs in Bugcrowd or HackerOne.
Model Drift Detection	Alert if agent behavior deviates from baseline accuracy (>5% change).	Monitored via MLflow or Evidently AI.
User Feedback Loop	Mechanism for reporting misbehavior (e.g., Slack channel, Jira ticket).	Tracked in Customer Support Ticketing System.
Policy Refresh Cycle	Firebreak rules updated **quarter	

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com